

Ed Goff, CISSP · 30 / 60 / 90 Day Plan

OT / Critical Infrastructure Security · IP & Data Protection · AI Governance · Supply Chain & Federal Compliance · Security Architecture

25+ Years Direct Experience · NIST CSF Contributor (OT SME) · NERC CIP · CyberArk · SailPoint · Agentic AI / NHI · Aligned to the CIO Mandate: IT Process Efficiency · Compliance · Digital Footprint

A warfighter turned cybersecurity executive — U.S. Air Force, 14 years securing critical energy infrastructure at a major investor-owned electric utility, and the nation's largest financial institutions — with a consistent track record of balancing risk and enabling the business to thrive: 595% delivery efficiency gain, \$200M DOE award enabled by security architecture, Zelle launched securely, OT solutions that utility engineers actually implemented. Mission-oriented, adversary-aware, uniquely qualified across two critical infrastructure sectors and direct DOD partnership.

● Days 1–30 Listen, Learn & Map

Build trust. Understand before proposing.

GUIDING PRINCIPLE

Earn trust before driving change. Walk the fab floor before writing a security plan. The CIO mandate is clear: IT process efficiency, compliance, and digital footprint expansion — with an operations-first lens where efficiency and throughput come before governance overhead. The track record is there: security programs that OT engineers implemented, mergers that closed on time, AI programs that launched with confidence. Every action in this 30 days is designed around understanding this world before proposing anything that changes it.

PEOPLE, STAKEHOLDERS & CURRENT STATE

Executive Relationships

Priority: Meet the CIO one-on-one in week one — understand the enterprise AI initiative in full: data flows, AI agent deployment, data integrity dependencies, and where the CISO is needed most.

Meet the CEO, CFO, General Counsel, and Board Audit Committee liaison. Understand how cybersecurity registers at the executive level and what the Board expects of the function. Meet every direct report — listen first, assess second. Understand what is working and what they wish leadership knew.

Cross-Functional Partners

Meet IT Engineering, Data & AI, Manufacturing Operations, Legal, Procurement, and HR — mapping where security intersects with each function and where I can be a stronger enabler of efficiency, not a source of friction.

Engage GRC and Internal Audit to map control commitments, CHIPS Act milestones, and open findings.

Meet site-level leaders: fab operations, supply chain, quality, and R&D — security strategy follows operational strategy.

FAB FLOOR, DATA & OT ENVIRONMENT

Manufacturing Site Visits — Priority One

Commit: Visit every manufacturing site in the first 30 days — understanding the operational environment before assessing its security.

Map OT architecture, ICS/SCADA systems, IT/OT convergence boundary, remote access posture, and all vendor and contractor access points — the same access governance discipline I applied across transmission, distribution, and generation environments in the electric utility sector.

Assess the enterprise data pipeline from fab floor to cloud — where manufacturing data originates, how it flows, and where data integrity risks exist upstream of AI decisions. Data integrity is the foundation the enterprise AI initiative is built on.

Inventory all non-human identities: embedded AI agents, service accounts, API keys, automation credentials, and MES access — establishing the NHI and data access baseline for AI governance.

SECURITY & DATA LANDSCAPE ASSESSMENT

Current-State Mapping

Assess the full security and data protection program — what exists, what is effective, and what requires immediate attention — without imposing change before understanding context.

Map OT security tooling and data protection maturity against the threat profile: nation-state IP espionage, ransomware targeting production systems, and supply chain compromise.

Assess CHIPS Act, DFARS, CMMC, and EAR/ITAR compliance posture — and evaluate the current third-party and vendor risk management program against what a company with these federal obligations and a defense customer base requires.

DELIVERABLE Written current-state assessment — OT/IT security posture; data protection and IP maturity; supply chain and vendor risk baseline; NHI and AI governance challenges; federal compliance map; prioritized risk map sequencing the 60-day plan. Presented to the CIO in Week 5.

● Days 31–60 Prioritize, Align & Begin

Translate findings into a sequenced plan.

GUIDING PRINCIPLE

Translate the assessment into a sequenced, capital-disciplined plan — OT and IP protection first, data protection and supply chain risk in parallel, AI governance and compliance threaded throughout. The balance between risk reduction and business enablement is not a concept here — it is a delivered outcome. 595% efficiency gain. Mergers closed on time. AI programs launched. The CIO's priorities: IT process efficiency, compliance, and digital footprint expansion. Security must enable each without creating overhead that slows operational throughput.

OT & IP SECURITY — THE PRIORITY PROGRAM

Process IP Protection Architecture

Design and begin implementing the layered IP protection architecture: network segmentation isolating process recipe and design data repositories, privileged access controls for fab engineers and vendor remote access, data classification establishing crown jewels.

Address the nation-state threat vector: validate that no ICS software update path exists without integrity verification — the confirmed APT41 2025 semiconductor campaign entry point.

DATA PROTECTION & CROWN JEWELS

Data-Centric Security Posture

Launch enterprise data discovery and classification to establish where the company's most sensitive data lives, how it moves, and who and what has access to it — the same foundational work I led implementing encryption, CASB, DLP, and certificate lifecycle management across one of the nation's largest financial institutions.

Engage the CIO and the business to identify and prioritize crown jewels — process recipes, design data, customer contracts, and federal program data — and build the layered data protection strategy: DLP, encryption, CASB, DSPM, and insider risk controls aligned to the multi-cloud data environment.

Implement data integrity monitoring at the enterprise data pipeline layer — ensuring manufacturing data feeding AI decisions has not been tampered with. Protecting the data accuracy the operations-first mandate depends on.

SUPPLY CHAIN & THIRD-PARTY RISK

Vendor Risk as a Strategic Priority

Establish or strengthen enterprise Third-Party Cyber Risk Management — building on the program I conceived and built from concept to operation inside a large regulated financial institution, partnering with Procurement, Legal, and Vendor Management. The MKS Instruments breach cascaded into \$250M in losses for Applied Materials in a single quarter from one vendor compromise.

Apply the DOE Cybersecurity Procurement Language framework I authored in 2014 — federal supply chain security guidance written specifically for ICS environments — to the vendor onboarding, assessment, and remediation management process.

Establish vendor remote access governance: just-in-time access, session recording, and certification for all third parties touching OT systems or IP repositories.

AI GOVERNANCE — ENTERPRISE AI PLATFORM

NHI & AI Agent Governance Framework

Present and align the NHI and AI agent governance framework to the CIO's team — adapted from a live framework I built for an enterprise AI agent platform inside a regulated financial institution.

Establish AI agent registration, lifecycle management, access boundaries, data minimization, logging, and human oversight standards for all AI agents embedded in manufacturing decisions.

DELIVERABLE 12-month roadmap — OT/IP security; data protection strategy with crown jewels prioritized; supply chain risk program standing; AI governance framework adopted; federal compliance closure plan; capital-disciplined investment case aligned to the company's operating model.

Chief Information Security Officer

Semiconductor Manufacturer

● Days 61–90 Execute, Measure & Communicate

Deliver visible progress. Establish the rhythm.

GUIDING PRINCIPLE

Demonstrate tangible progress on the CIO's three priorities: IT process efficiency, compliance, and digital footprint. The measure of success is not security controls implemented — it is the business outcomes they protect and enable. The company is manufacturing, innovating, and growing. Security is the partner that makes that possible at the right level, at the right time, without becoming the constraint on operational throughput or data-driven decision-making.

OT & IP PROTECTION — OPERATING

Controls Hardened & Auditable

IP protection architecture operating — segmentation enforced, privileged access governance live for fab engineers and vendors, crown jewels identified and protected. ICS software update integrity verification established — every OT update validated against the APT41 2025 supply chain attack vector before deployment.

OT monitoring live — asset inventory complete, anomaly detection operational, telemetry integrated into SIEM, security operations trained on OT-specific threat indicators.

DATA PROTECTION — MATURING RAPIDLY

Data-Centric Posture Operational

Enterprise data classification deployed — process recipes, design files, and federal program data identified, documented, and protected. The enterprise data estate is classified, governed, and monitored.

Data protection elevated beyond perimeter defense: DLP enforced, DSPM vendor selected, CASB coverage extended, Zero Trust data policies live in highest-risk environments.

Replicating the data protection architecture I designed and implemented across one of the nation's largest financial institutions.

Insider risk controls operational — behavioral analytics and data exfiltration detection running, particularly for vendor and contractor access touching IP repositories and EAR/ITAR-controlled technical data.

SUPPLY CHAIN & THIRD-PARTY RISK — STANDING

Vendor Risk Program Operational

Enterprise Third-Party Cyber Risk Management program standing — vendor onboarding security requirements, risk-tiered assessment cadence, and remediation plan management in place. Procurement and Legal aligned. Every vendor with access to OT systems or IP repositories assessed.

Vendor remote access governance fully operational — just-in-time access, session recording, and certification running. Supply chain attack surface documented and managed.

AI GOVERNANCE & FEDERAL COMPLIANCE

NHI Framework Enforced — Federal Posture Visible

AI agent governance operational — every AI agent registered, access-certified, and operating within defined data minimization boundaries. Shadow AI inventory established. CHIPS Act cybersecurity controls mapped and defensible. DFARS/CMMC remediation underway by contract risk. EAR/ITAR technical data governance operational — access controls, geographic restrictions, and audit trails in place.

Security as a Business Metric — the CIO's Language

Executive dashboard live — OT security posture, IP protection, data protection maturity, supply chain risk coverage, AI governance, and federal compliance in business risk language. IT process efficiency and digital footprint metrics alongside security posture. Security integrated into the business planning cycle as a partner, not a gatekeeper. The company is manufacturing, innovating, and growing. The security program is aligned to enable every part of that — protecting what matters most, at the right level, at the right time.

DELIVERABLE Strategic briefing to the CIO — what was learned, what was built across OT security, data protection, supply chain risk, AI governance, and federal compliance, and what the 12-month program looks like to sustain momentum and scale with the company's growth.

"The right people, machines, and agents — the right access — the right data — protected at the right level, at the right time, so the business can thrive."

Illustrative example. Company, individuals, and internal details generalized.

Portfolio: [edgoff.net](#) · [edgoff33@gmail.com](#) · 919-995-1529 · [linkedin.com/in/edgoff3](#)

© 2026 Ed Goff. All rights reserved.